

Documentación de Seguridad y Resiliencia

Triage de Leads — Taller de Reparación de PC

1. Minimización de datos

El nodo de IA recibe únicamente el asunto y el cuerpo del email del cliente — no se le pasan headers completos, metadatos de Gmail, ni el email del remitente. Los datos de contacto (email, teléfono) se almacenan una sola vez en la tabla Clientes y se referencian por relación desde Leads, en vez de duplicarse en cada registro. El trigger de Gmail está configurado en modo "From now on" (solo emails nuevos desde la activación), evitando procesar y exponer el historial completo de la casilla en cada corrida.

2. Rutas de error (resiliencia)

El nodo de IA tiene configurado **On Error: Continue Using Error Output**, con 3 reintentos automáticos (Retry On Fail) antes de considerarlo un fallo definitivo. Si el fallo persiste, la ejecución no se corta: se deriva por la salida de error hacia un nodo que registra el incidente en la tabla **Errores** de Notion (fecha, nodo de origen, mensaje de error, y el lead relacionado si ya existía). Esto evita dos problemas: que un fallo puntual de la API rompa todo el workflow, y que un lead se pierda silenciosamente sin dejar rastro.

Se verificó este mecanismo forzando un error real (modelo de IA inexistente), confirmando que el registro se crea correctamente en la tabla Errores sin detener el resto del sistema.

3. Puntos de Human-in-the-Loop (HITL)

Antes de contactar al cliente final, el flujo se detiene en un nodo **Wait** (modo "On Webhook Call"), que congela la ejecución hasta que un humano aprueba desde Slack. Mientras el checkbox/aprobación no ocurre, ningún dato avanza hacia el cliente — es un punto de pausa real a nivel de ejecución, no un simple filtro que se puede saltar.

Caso de estudio: vulnerabilidad detectada y corregida

Durante las pruebas se detectó que el propio bot de Slack (Slackbot-LinkExpanding, encargado de generar la vista previa de links) hacía una petición GET automática a la URL de reanudación apenas se publicaba el mensaje — aprobando el flujo sin ninguna intervención humana real. Se corrigió envolviendo la URL entre backticks en el mensaje de Slack (para que no se trate como link clickeable) y desactivando la opción "Unfurl Links" del nodo. Este hallazgo se documenta como ejemplo concreto de un riesgo de seguridad no evidente en un sistema HITL: una automatización de terceros (el propio bot de la plataforma de notificación) puede disparar accidentalmente una acción crítica si el mecanismo de aprobación depende únicamente de recibir una petición HTTP a una URL, sin autenticación adicional.

4. Credenciales

Todas las integraciones (Gmail, Slack, Notion) usan OAuth2, sin contraseñas ni tokens expuestos en el propio workflow. El acceso al modelo de IA se gestiona mediante créditos administrados por n8n (AI Gateway), sin necesidad de almacenar una API key propia de Anthropic en el sistema. Ninguna credencial aparece en las capturas de pantalla ni en el video demo de este entregable.